Executive Summary: Quantitative Risk Modelling, Supply Chain Security and Disaster Recovery

Author: Abinel Madzivire

Module: Security and Risk Management

University of Essex

October 2026

Executive Summary

1. Business Context and Quantitative Risk-Modelling Approach

The proposed digitalisation of the company, incorporating international supply chains, automated warehouses, cloud-connected systems and a continuously available online store, offers significant commercial opportunities. However, it also increases dependence upon cyber-physical systems, third-party suppliers, networks, software platforms, accurate digital information and geographically dispersed logistics. Digital supply chains can improve resilience, visibility and operational efficiency, but greater interconnection also creates pathways through which cyber incidents, supplier failures and operational disruption may propagate across organisational boundaries (Kaur, Gupta and Singh, 2024; Dash et al., 2024).

Automated warehouses add further dependencies involving Warehouse Management Systems (WMS), autonomous mobile robots, Automated Guided Vehicles (AGVs), Internet of Things (IoT) sensors and automated storage and retrieval systems. Ellithy et al. (2024) demonstrate the increasing integration of automated equipment, information systems and data-collection technologies within warehousing, while Pu et al. (2024) show experimentally that manipulation of industrial robotic data can compromise system integrity and availability. Recent research consequently treats

cybersecurity, physical resilience, traceability and supply-chain continuity as interconnected concerns rather than independent risks (Castillo-Villar et al., 2026).

Aven and Thekdi (2025) argue that risk assessment should consider not merely expected events but also potential consequences, uncertainty, assumptions and the strength of the knowledge supporting probability judgements. This perspective is particularly relevant because the case provides no historical company data concerning cyber incidents, supplier failures, warehouse downtime, defect rates or logistics interruptions. Consequently, the probabilities presented below should be interpreted as decision-support estimates under uncertainty, rather than objectively known frequencies.

A quantitative approach is appropriate because the assignment requires estimates of the probabilities that digitalisation may adversely affect product quality and availability. Chapters 3–5 of Aven and Thekdi (2025) provide the theoretical basis for measuring risk, structuring quantitative risk assessments and applying techniques including Monte Carlo simulation, Bayesian analysis and sensitivity analysis. A FAIR-informed Monte Carlo probabilistic model supplemented by Bayesian reasoning is therefore adopted. FAIR provides a useful structure for distinguishing event frequency from consequences and has been applied to cyber-risk quantification within the logistics sector (Seid et al., 2024). Bayesian reasoning is complementary because probability estimates can subsequently be updated as the organisation obtains actual incident, supplier, quality and downtime evidence. Liu, Zhou and Yuen (2026), for example, integrate Bayesian Networks with FAIR to analyse cyber-physical resilience where technological, organisational and external risk factors interact.

Monte Carlo simulation is preferable to relying exclusively upon a deterministic risk matrix because uncertain inputs can be represented as probability distributions rather than fixed values. Aven and Thekdi (2025) emphasise the importance of examining uncertainty and model sensitivity when interpreting quantitative risk assessments, while Wang, Neil and Fenton (2020) demonstrate how Monte Carlo and Bayesian techniques can enhance conventional FAIR analysis. In this model, uncertain probabilities are therefore represented using low, most-likely and high estimates within Beta-PERT distributions.

The principal assumptions are that the model operates over a one-year horizon; a material quality event means one capable of producing customer-visible deterioration, rejection or reputational consequences; a material availability event means disruption capable of meaningfully affecting fulfilment; and the individual pathways are initially treated as conditionally independent for aggregation. These assumptions should be reconsidered when company evidence becomes available.

For each risk pathway:

$$P(\text{material loss}_i) = P(\text{event}_i) \times P(\text{material consequence} \mid \text{event}_i)$$

and the probability of at least one material event is:

$$P(\text{any material event}) = 1 - \prod(1 - P_i).$$

Two hundred thousand Monte Carlo iterations are used to represent uncertainty across the selected pathways.

Table 1: Quantitative Risk Estimates for Product Quality and Supply-Chain Disruption Pathways

Risk pathway	Annual event probability: low / likely / high	Conditional material consequence: low / likely / high	Estimated stand-alone annual probability
Supplier quality variation/substitution	6% / 12% / 25%	20% / 40% / 65%	**5.4%**
WMS/automation misconfiguration	3% / 8% / 18%	20% / 45% / 70%	**4.0%**
Environmental/sensor-control failure	4% / 10% / 22%	15% / 35% / 60%	**3.9%**
Product/master-data integrity compromise	2% / 6% / 15%	30% / 55% / 80%	**3.8%**
Human/process error during transformation	8% / 16% / 30%	15% / 30% / 55%	**5.4%**
Supplier/logistics interruption	10% / 22% / 40%	30% / 55% / 80%	**12.7%**
Ransomware/cyberattack	3% / 8% / 18%	45% / 70% / 90%	**6.1%**
WMS/robotics outage	5% / 12% / 25%	35% / 60% / 80%	**7.7%**
Cloud/network outage	2% / 5% / 12%	35% / 60% / 85%	**3.4%**
Transport/customs/geopolitical disruption	8% / 18% / 35%	25% / 50% / 75%	**9.6%**
Third-party digital dependency failure	3% / 8% / 18%	30% / 55% / 80%	**4.9%**

For illustration, the Beta-PERT expected annual probability of supplier-quality variation is approximately 13.2%, while its expected probability of creating a material consequence is approximately 40.8%. Multiplication produces a stand-alone material-loss probability of approximately 5.4%.

The aggregated model estimates an annual probability of approximately 20.5% for at least one material product-quality event and approximately 37.1% for at least one material supply-chain availability disruption. The corresponding model-uncertainty ranges are approximately 14.9–26.8% and 28.8–45.8%, respectively. These results should not be interpreted as precise forecasts. Consistent with Aven and Thekdi (2025), the numerical outputs must be interpreted alongside the assumptions and strength of knowledge underlying them.

The principal contributors to quality risk are supplier-quality variation and human/process error, followed by WMS misconfiguration, environmental-control failure and compromise of product or master data. The principal availability risks are supplier/logistics interruption, transport and customs disruption, WMS/robotics outages and cyberattack. This supports Hasani, Haseli and Deveci's (2025) finding that digital-supply-chain risk emerges from interconnected technological, organisational and operational factors.

The model's principal limitation is its assumption of conditional independence. A supplier cyberattack could simultaneously produce data corruption, logistics interruption and warehouse downtime. The aggregated probabilities may therefore underestimate correlated or cascading events. Aven and Thekdi (2025) emphasise the importance of recognising modelling limitations and conducting sensitivity analysis rather than treating a quantitative result as certain. Future modelling should therefore use observed conditional probabilities within a fuller Bayesian Network and conduct sensitivity analysis to establish which assumptions most strongly influence the results. This is also consistent with Liu, Zhou and Yuen (2026) and Dash et al. (2024).

2. Risk-Treatment Priorities

Aven and Thekdi (2025) distinguish risk assessment from risk-management decision-making: numerical probabilities support decisions but should not determine them mechanically. Management must also consider uncertainty, potential consequences, resilience, commercial priorities and stakeholder expectations. The calculated probabilities should therefore guide prioritisation rather than act as fixed acceptance thresholds.

Recommendations should be implemented in the following commercial priority order:

- **Protect product availability and supply continuity.** Critical inputs should be dual- or multi-sourced geographically where practicable, supported by safety-stock thresholds and alternative logistics providers. Supplier contracts should specify security, quality, resilience, recovery and incident-notification obligations. Cyber-resilience should form part of procurement assessment rather than relying solely upon price and conventional product-quality indicators. Kaur, Gupta and Singh (2024) demonstrate that integrating supplier selection with cybersecurity investment can improve digital supply-chain resilience, while NIST (2024) places cybersecurity supply-chain risk management within organisational governance.
- **Protect product quality and information integrity.** Product specifications, recipes, warehouse instructions, labels and quality-control information should be protected through role-based access control, cryptographic integrity mechanisms, segregation of duties and immutable audit logging. IoT sensors should be authenticated, regularly calibrated and monitored for abnormal environmental readings. Critical quality decisions should retain independent verification so that automation does not become an uncontrolled single point of failure.
- **Reduce cyber-physical single points of failure.** WMS, robotics and warehouse automation require redundant components, tested manual fallback procedures and recoverable operating modes. Supplier and warehouse connections should apply Zero Trust principles, multifactor authentication, least privilege, privileged-access controls, vulnerability management and network segmentation. Castillo-Villar et al. (2026) similarly emphasise resilience, secure

engineering and monitoring throughout interconnected manufacturing and supply-chain environments.

- **Create measurable security and resilience governance.** The company should implement an information security management system aligned with ISO/IEC 27001:2022, business-continuity arrangements aligned with ISO 22301:2019, and ICT-continuity processes aligned with ISO/IEC 27031:2025. Quantitative risks should be reviewed periodically and Bayesian updating used as actual operational evidence accumulates.

If the proposed controls reduce cyber and automation pathways by approximately 40–60% and externally driven supplier and transport pathways by approximately 25–35%, the model indicates illustrative residual probabilities of approximately 11.5% for quality loss and 23.2% for supply-chain disruption. These are risk-reduction scenarios rather than guaranteed post-control outcomes.

3. Business Continuity and Disaster-Recovery Design

Ms O'dour's requirement that the online shop remains available continuously with less than one minute of changeover time and no more than one minute of data loss establishes an RTO below 60 seconds and an RPO below 60 seconds. These objectives materially influence the technical architecture. Conventional backup-and-restore and pilot-light approaches cannot reliably achieve such recovery objectives, while warm standby may also exceed the required RTO.

A geographically separated multi-region active/active or highly automated active/standby architecture is therefore recommended. The preferred platform is Amazon Web Services (AWS), subject to detailed financial, contractual and data-residency assessment. Application workloads should operate across geographically

separated regions using automated health monitoring and global traffic management. Containerisation should enable rapid redeployment and reduce unnecessary platform dependence.

Database resilience can be provided through Amazon Aurora Global Database, which supports cross-region replication and rapid promotion of a secondary region. AWS documents typical replication latency of below one second and the ability to promote a secondary region rapidly. Nevertheless, service-specific capabilities do not themselves guarantee a complete <60-second recovery; the entire application, authentication, DNS, networking and database failover process must be demonstrated through realistic testing.

Replication must be supplemented by independent immutable backups, cross-account copies, point-in-time recovery and documented recovery procedures because replication may reproduce corruption, erroneous modification or malicious deletion. Failover exercises should therefore be undertaken at least quarterly and measured directly against the required RTO and RPO. This reflects the wider risk-science principle that resilience claims should be supported by evidence rather than assumed from system design alone (Aven and Thekdi, 2025).

Vendor lock-in represents an additional strategic risk. Heavy dependence upon proprietary databases, identity mechanisms and cloud APIs can increase future migration cost and complexity. The organisation should therefore use containerised services, open APIs, standard data formats, PostgreSQL-compatible technologies where practicable, portable infrastructure-as-code and documented data-export and exit procedures. This does not necessarily justify the considerably greater cost and complexity of operating continuously across multiple cloud providers; rather, the

company should maintain a credible ability to migrate without redesigning its entire digital operation.

4. Regulatory, Security and Professional Requirements

The assignment refers to GDPR as a directive; technically, GDPR is a regulation. A UK-based organisation must comply with the UK GDPR and the Data Protection Act framework, including subsequent amendments introduced through the Data (Use and Access) Act 2025. Security measures should reflect the level of risk and protect confidentiality, integrity, availability and resilience.

The high-profile status of customers does not justify unnecessary collection of personal information. Privacy by design and default, purpose limitation, data minimisation, encryption, multifactor authentication, retention controls, secure logging and appropriate international-transfer safeguards should therefore be embedded within the digitalisation programme.

Where payment-card information is processed, PCI DSS v4.0.1 should also form part of the security architecture. The organisation should minimise the size of its own cardholder-data environment by using a compliant specialist payment provider wherever commercially appropriate.

These obligations reinforce Aven and Thekdi (2025)’s broader risk-management principle that decisions must take account of regulatory, ethical, organisational and stakeholder consequences in addition to calculated probabilities.

Conclusion

Digitalisation should proceed only alongside quantifiable risk governance, supply-chain resilience and security-by-design. Under the stated assumptions, the

quantitative model estimates approximately a 20.5% annual probability of a material product-quality event and 37.1% annual probability of a material supply-chain disruption before implementation of the proposed controls. The results justify supplier diversification, warehouse resilience, integrity monitoring, cyber-physical security controls and robust business-continuity arrangements.

Aven and Thekdi (2025) provide an important interpretative framework: quantitative results should not be mistaken for certainty. Their value lies in making assumptions and uncertainty explicit and enabling decision-makers to compare alternative risk treatments rationally. The company should therefore replace initial scenario estimates progressively with operational evidence and use Bayesian updating and sensitivity analysis to improve the model.

Commercially, the priority is maintaining product availability and internationally recognised quality. The second is safeguarding integrity across the automated supply chain, while the third is ensuring that the online business can meet its sub-one-minute recovery objectives. A tested multi-region architecture, supported by an ISO/IEC 27001-aligned security management system and structured business-continuity governance, offers the strongest basis for achieving these objectives while maintaining regulatory compliance and customer confidence.

References

Aven, T. and Thekdi, S. (2025) *Risk Science: An Introduction*. 2nd edn. Abingdon: Routledge. doi:10.4324/9781003494317.

Castillo-Villar, K.K., Dai, H., Martinez Medina, G. and Mehrzadi, H. (2026) ‘Cybersecurity for smart and resilient manufacturing and supply chains: A systematic

review of the evolving knowledge base', *Computers & Industrial Engineering*, 220, 112244. doi:10.1016/j.cie.2026.112244.

Dash, A., Sarmah, S.P., Tiwari, M.K., Jena, S.K. and Glock, C.H. (2024) 'Cybersecurity investments in supply chains with two-stage risk propagation', *Computers & Industrial Engineering*, 197, 110519. doi:10.1016/j.cie.2024.110519.

Ellithy, K., Salah, M., Fahim, I.S. *et al.* (2024) 'AGV and Industry 4.0 in warehouses: a comprehensive analysis of existing literature and an innovative framework for flexible automation', *The International Journal of Advanced Manufacturing Technology*, 134, pp. 15–38. doi:10.1007/s00170-024-14127-0.

Hasani, A., Haseli, G. and Deveci, M. (2025) 'Analyzing operational risks of digital supply chain transformation using hybrid ISM-MICMAC method', *OPSEARCH*, 62, pp. 583–607. doi:10.1007/s12597-024-00792-y.

Information Commissioner's Office (ICO) (2026) *Data protection by design and by default*. Wilmslow: Information Commissioner's Office.

Information Commissioner's Office (ICO) (2026) *The Data (Use and Access) Act 2025 – what does it mean for organisations?* Wilmslow: Information Commissioner's Office.

ISO (2019) *ISO 22301:2019 Security and resilience — Business continuity management systems — Requirements*. Geneva: International Organization for Standardization.

ISO/IEC (2022) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Geneva: International Organization for Standardization.

ISO/IEC (2025) *ISO/IEC 27031:2025 Cybersecurity — Information and communication technology readiness for business continuity*. Geneva: International Organization for Standardization.

Kaur, H., Gupta, M. and Singh, S.P. (2024) 'Integrated model to optimize supplier selection and investments for cyber resilience in digital supply chains', *International Journal of Production Economics*, 275, 109338. doi:10.1016/j.ijpe.2024.109338.

Liu, X., Zhou, Y. and Yuen, K.F. (2026) 'Assessing cybersecurity resilience of digital ports using a BN-FAIR framework', *Transportation Research Part D: Transport and Environment*, 156, 105379. doi:10.1016/j.trd.2026.105379.

National Institute of Standards and Technology (NIST) (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29. Gaithersburg, MD: NIST. doi:10.6028/NIST.CSWP.29.

National Institute of Standards and Technology (NIST) (2024) *NIST Cybersecurity Framework 2.0: Quick-Start Guide for Cybersecurity Supply Chain Risk Management*. NIST SP 1305. Gaithersburg, MD: NIST. doi:10.6028/NIST.SP.1305.

PCI Security Standards Council (2024) *Payment Card Industry Data Security Standard v4.0.1*. Wakefield, MA: PCI Security Standards Council.

Pu, H., He, L., Cheng, P., Chen, J. and Sun, Y. (2024) 'CORMAND2: A deception attack against industrial robots', *Engineering*, 32, pp. 186–201. doi:10.1016/j.eng.2023.01.013.

Seid, E., Satheesh, S., Popov, O. and Blix, F. (2024) ‘FAIR: Cyber Security Risk Quantification in Logistics Sector’, *Procedia Computer Science*, 237, pp. 783–792. doi:10.1016/j.procs.2024.05.166.

Wang, J., Neil, M. and Fenton, N. (2020) ‘A Bayesian network approach for cybersecurity risk assessment implementing and extending the FAIR model’, *Computers & Security*, 89, 101659. doi:10.1016/j.cose.2019.101659.